Mitigación de amenazas en redes y dispositivos

Objetivo

Reconocer amenazas comunes en redes, dispositivos y plataformas digitales, proponiendo **acciones de mitigación alineadas a ISO 27001**, mediante análisis de casos y ejemplos prácticos.

Activación

Recibes un correo que parece ser del banco, pero te pide hacer clic en un enlace extraño.

BancoEstado®

Estimado Cliente,

ASUNTO: **Contrato** n.º NB06491021

Junto con saludarlo queremos informarle que el 09/09/2016 vence el plazo para la actulizacion de la Tarjeta de coordenadas del contrato en el epígrafe .

Sobre la base de la posición de contrato en términos meramente de orientación , indicar a los clientes de BancoEstado S.A que es obligatorio el proceso de activación

En caso de que esta ultima disposicion no se cumpla procederemos hacerlo de forma sistematica y se producira los siguientes cargos a su cuenta.

INTERES $120.590
COMISION DE GESTION $ 28.110

TOTAL $ 14

ACTIVACION DE T

Este importe no sera cobrado si la s
08/09/2016

Para iniciar la activacion >>>>> : ACTIVACION DE TARJETA DE

¿Qué vulnerabilidad se observa y qué medidas tomarías primero?

El caso muestra un phishing bancario; la acción correcta es no abrir el enlace, eliminar y reportar el correo, y prevenir con contraseñas seguras, MFA y filtros antiphishing, según ISO 27001 A.9 y A.13.

Activación

En tu Wi-Fi, un vecino se conecta sin permiso porque tu contraseña es “12345678”.

¿Qué vulnerabilidad se observa y qué medidas tomarías primero?

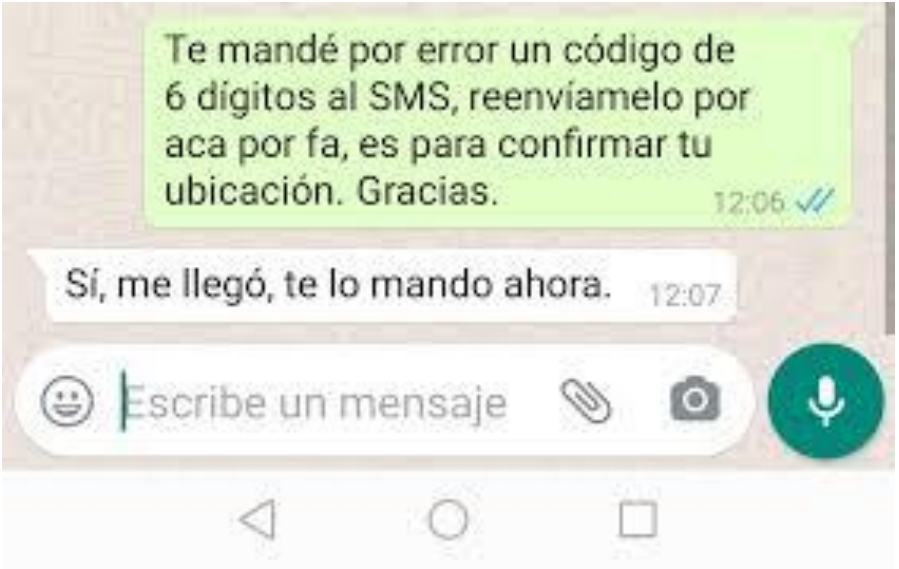
Es una **contraseña débil en Wi-Fi**; la solución es cambiarla por una clave robusta y usar **WPA3/WPA2**, según ISO 27001 **A.9** y **A.13**.

Ingeniería Social

La **ingeniería social** es el engaño a personas para obtener información o acceso, aprovechando la confianza o el descuido en lugar de atacar directamente la tecnología.

Ingeniería Social: Phishing

El **phishing** es un fraude digital donde se envían mensajes falsos que imitan a entidades reales para robar contraseñas, datos o dinero.



Ingeniería Social: Spoofing

Se centra en **suplantar la identidad digital** de otra persona o entidad (correo, dirección IP, número de teléfono, dominio web) para aparentar legitimidad.

amazon

Assistance Center

Dear Customer,

We believe that an unauthorized party may have accessed your account. To protect your information, we have:

- Disabled the password to your account.
- Reversed any modifications made by this party.
- Canceled any pending orders. You can ignore any confirmation emails that you received for these orders.
- If appropriate, refunded purchases to your payment instrument.
- Restored any gift card b nay take 2 to 3 days for the gift card balance to be avail

https://ctr-manageramazonw.servebeer
com/?iyh_re
Ctrl+clic para seguir vínculo

Just log in https://amazon.com and follow the instructions in your account notifications to see what information you need to provide. Please send the missing information by 21 October 2019.

Ingeniería Social: Baiting

El **baiting** es una forma de ingeniería social que consiste en “tentar” a la víctima con algo atractivo (como un archivo gratis, un USB olvidado, un enlace de descarga, etc.) para que lo abra y así se instale malware o entregue información sin darse cuenta.

Ingeniería Social: Pretexting

El **pretexting** es una técnica de ingeniería social en la que el atacante inventa una historia o identidad falsa (un “pretexto”) para ganarse la confianza de la víctima y obtener información confidencial, como hacerse pasar por soporte técnico o un funcionario de la empresa.

Seguridad en redes inalámbricas

WEP, WPA: Protocolos obsoletos

WPA3: Estándar recomendado

	WPA	WPA2	WPA3
Release year	2003	2004	2018
Encryption	TKIP	CCMP/AES	CCMP-256
Security level	Not secure	Standard until 2021	Very secure; New standard

Buenas prácticas:

- Cambiar contraseña periódicamente.
- Ocultar SSID.
- Segmentar redes (invitados vs corporativa).

Seguridad en la nube

Riesgos: configuraciones abiertas en AWS, bucket S3 sin permisos, etc.

Medidas:

- Cifrado de datos en reposo y en tránsito.
- Autenticación multifactor (MFA).
- Revisión periódica de permisos.

Seguridad en dispositivos móviles

Riesgos: apps maliciosas, robo de información.

Estrategias:

- Políticas MDM (Mobile Device Management).
- Bloqueo remoto y borrado en caso de pérdida.
- Evitar redes Wi-Fi públicas inseguras.

Conexión con ISO 27001

A.9 Control de accesos: contraseñas seguras, MFA, gestión de permisos.

A.13 Seguridad en comunicaciones: cifrado en Wi-Fi, VPN seguras, bloqueo de protocolos inseguros.

Cierre

¿Qué amenazas son más cercanas a su vida diaria?